SK Shieldus Rookies

경영진 보고

# 모의 교육 플랫폼 취약점 진단 결과

러닝브릿지(가상) 온라인 교육 플랫폼

| 전체 위험 수준 | 진단 일자 | 문서 번호 | 작성 |
| --- | --- | --- | --- |
| 심각 | 2026-10-07 | SCAN-20261007-001-E | SK쉴더스 루키즈 34기 1석삼조 팀 |

본 보고서는 SK쉴더스 루키즈 교육과정의 프로젝트 산출물이며, SK쉴더스의 공식 진단 보고서가 아닙니다.

# 주문 서버에 외부인이 개인정보를 쉽게 접근할 수 있습니다

러닝브릿지의 온라인 교육 플랫폼에서 개인정보 보호에 심각한 취약점이 발견되었습니다. 120,000명의 회원 정보를 포함한 시스템이 외부 공격에 노출되어 있으며, 공격자가 이를 악용할 경우 회원의 개인정보가 유출될 수 있습니다.

**전체 위험 수준**

**심각**

개인정보를 처리하는 자산에 '상' 위험 취약점이 있음

**취약 항목**

**7** 건 / 점검 19개 항목

상 7건, 중 0건, 하 0건

**영향받는 개인정보 처리 자산**

**1** 개

웹 서비스 (localhost:5000)

## 핵심 위험

### 1 주석에 민감한 정보가 노출되어 외부인이 시스템을 파악할 수 있음 상

주석을 통해 시스템 구조와 계정 정보가 노출되어 외부 공격자가 이를 악용할 수 있습니다.

**유사 사례** 대구한의대학교 · 권한 확인 누락, 개인정보 노출 동일 결함 **과태료 360만 원**
**유사 사례** ㈜골프존 · 권한 확인 누락, 개인정보 노출 동일 결함 **과징금 75억 400만 원, 과태료 540만 원, 공표명령**

### 2 재인증 없이 개인정보 변경 가능 상

재인증 절차 없이 개인정보가 변경될 수 있어, 공격자가 임의로 회원 정보를 수정할 수 있습니다.

**관련 법령** 개인정보 보호법 제29조(안전조치의무) 검토 전
**관련 법령** 개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리) 검토 전
**관련 법령** 개인정보의 안전성 확보조치 기준 제6조 제2항(접근통제) 검토 전
**유사 사례** 루이비통코리아(유) · 권한 확인 누락, 본인확인 미흡 동일 결함 **과징금 213억 8,500만 원, 공표명령**
**유사 사례** 인크루트㈜ · 크리덴셜 스터핑, 이상행위 탐지 미흡 동일 결함 **과징금 7,060만 원, 과태료 360만 원, 결과공표**

### 3 임시 비밀번호가 평문으로 노출되어 비인가자가 접근 가능 상

임시 비밀번호가 평문으로 노출되어 비인가자가 쉽게 계정에 접근할 수 있습니다.

**관련 법령** 개인정보 보호법 제29조(안전조치의무) 검토 전
**관련 법령** 개인정보의 안전성 확보조치 기준 제6조 제2항(접근통제) 검토 전

**유사 사례** (주)동행복권 · 비밀번호 재설정 결함, 권한 확인 누락 동일 결함 **과징금 5억 300만 원, 과태료 480만 원, 공표명령**

## 관련 법령과 인증기준

| 조항·기준 | 관련 취약점 | 상태 |
|---|---|---|
| 개인정보 보호법 제29조(안전조치의무) | 6건 | 검토 전 |
| 개인정보의 안전성 확보조치 기준 제5조 제5항(접근 권한의 관리) | 5건 | 검토 전 |
| 개인정보의 안전성 확보조치 기준 제6조 제2항(접근통제) | 4건 | 검토 전 |
| ISMS-P 2.10.3 공개서버 보안 | 1건 | 검토 전 |
| ISMS-P 2.5.4 비밀번호 관리 | 3건 | 검토 전 |
| ISMS-P 2.5.3 사용자 인증 | 2건 | 검토 전 |
| ISMS-P 2.6.3 응용프로그램 접근 | 2건 | 검토 전 |
| ISMS-P 3.2.1 개인정보 현황관리 | 1건 | 검토 전 |

## 유사 처분·보도 사례

**과징금 처분** 개인정보위 2023-10-12 동일 결함

**대구한의대학교 · 권한 확인 누락, 개인정보 노출**

**과태료 360만 원**

**과징금 처분** 개인정보위 2024-05-09 동일 결함

**(주)골프존 · 권한 확인 누락, 개인정보 노출**

**과징금 75억 400만 원, 과태료 540만 원, 공표명령**

**과징금 처분** 개인정보위 2026-02-12 동일 결함

**루이비통코리아(유) · 권한 확인 누락, 본인확인 미흡**

**과징금 213억 8,500만 원, 공표명령**

**과징금 처분** 개인정보위 2023-07-12 동일 결함

**인크루트(주) · 크리덴셜 스터핑, 이상행위 탐지 미흡**

**과징금 7,060만 원, 과태료 360만 원, 결과공표**

외 1건은 앞 장의 핵심 위험별 유사 사례에 있습니다.

'검토 전'은 AI가 매핑하고 담당자가 아직 확인하지 않은 항목입니다. 확정 전까지는 위반 소지로 보아야 합니다.
사례 등급: 동일 결함 = 인증기준과 취약점 유형이 모두 같음, 같은 유형 = 취약점 유형이 같음, 관련 통제 = 인증기준만 같음.

## 과징금 노출과 감경 여지

**최대 노출액 (법정 상한)**

**1억 5,000만 원**

연 매출 50억 원의 3%. 제29조(안전조치의무)에 취약점 6건이 걸려도 상한은 한 번만 적용

**투자 감경 반영 시 (예시)**

**9,000만 원**

보호 투자·조치 기록이 있으면 최대 40% 감경. 지금은 기록이 없어 감경 근거가 없음

**10% 특례 시나리오**

**5억 원**

반복 위반, 1천만 명 이상 피해, 시정명령 불이행으로 유출될 때만. 현재 요건 해당 없음

### 같은 유형 결함의 실제 과징금

유사 처분 15건 · 최소 329만 원 · 중앙값 5억 300만 원 · 최대 4,235억 7,500만 원

| 사례 | 처분일 | 과징금 |
|---|---|---|
| 쿠팡 주식회사 (유출 관련) · 권한 확인 누락, 본인확인 미흡 동일 결함 | 2026-06-11 | **4,235억 7,500만 원** |
| (주)케이에스한국고용정보 · 파라미터 변조, 관리자 페이지 노출 관련 통제 | 2026-04-23 | **35억 3,700만 원** |
| 한화호텔앤드리조트(주) · 권한 확인 누락 관련 통제 | 2024-08-28 | **1억 8,531만 원** |
| 현대자동차(주) · 보안 패치 미적용, 개인정보 노출 같은 유형 | 2024-08-28 | **329만 원** |

법정 상한은 최대치이며 예상 부과액이 아닙니다. 실제 부과액은 과징금 부과기준의 산정 단계(기준금액, 감경, 조정)를 거쳐 정해집니다.
유사 사례 금액이 상한보다 큰 것은 사례 기업의 매출 규모가 더 크기 때문이며, 같은 결함이 실제로 처분받은 규모를 보여주기 위한 참고값입니다.

## 조치 로드맵

### 즉시 1주 이내

**주석 내 민감 정보 삭제 및 마스킹 처리**

주석 내 정보 누출

**재인증 절차 강화 및 서버 검증 로직 추가**

불충분한 인증 절차

### 단기 1개월 이내

**비밀번호 복구 절차 강화 및 임시 비밀번호 암호화**

취약한 비밀번호 복구 절차

**비밀번호 정책 강화 및 서버 검증 추가**

유추 가능한 비밀번호, 낮은 복잡도의 비밀번호 정책

### 중기 분기 이내

**문의글 접근 권한 및 댓글 작성 권한 검증 강화**

타인 문의글 열람, 타인 문의글 댓글 작성

## 경영진 결정이 필요한 사항

1 주석 내 민감 정보 삭제 작업을 위해 이번 주말 점검 시간을 승인해 주십시오.

2 재인증 절차 강화를 위한 개발 인력 및 예산을 승인해 주십시오.

3 보안 투자 기록을 남기기 위한 조치·투자 기록 관리를 지정해 주십시오.

취약점별 상세 내용과 조치 방법은 실무진용 상세 보고서(SCAN-20261007-001-T)에 있습니다. 법령·인증기준 매핑 중 24건은 아직 담당자 검토 전입니다.